

Certification of translation

I hereby certify that the following document has been translated into English by me, Timothy Ian Cramp, a translator authorised by the Swedish Legal, Financial and Administrative Services Agency (translator number 890).

The document comprises seven pages (excluding this one) and each page bears my stamp and signature

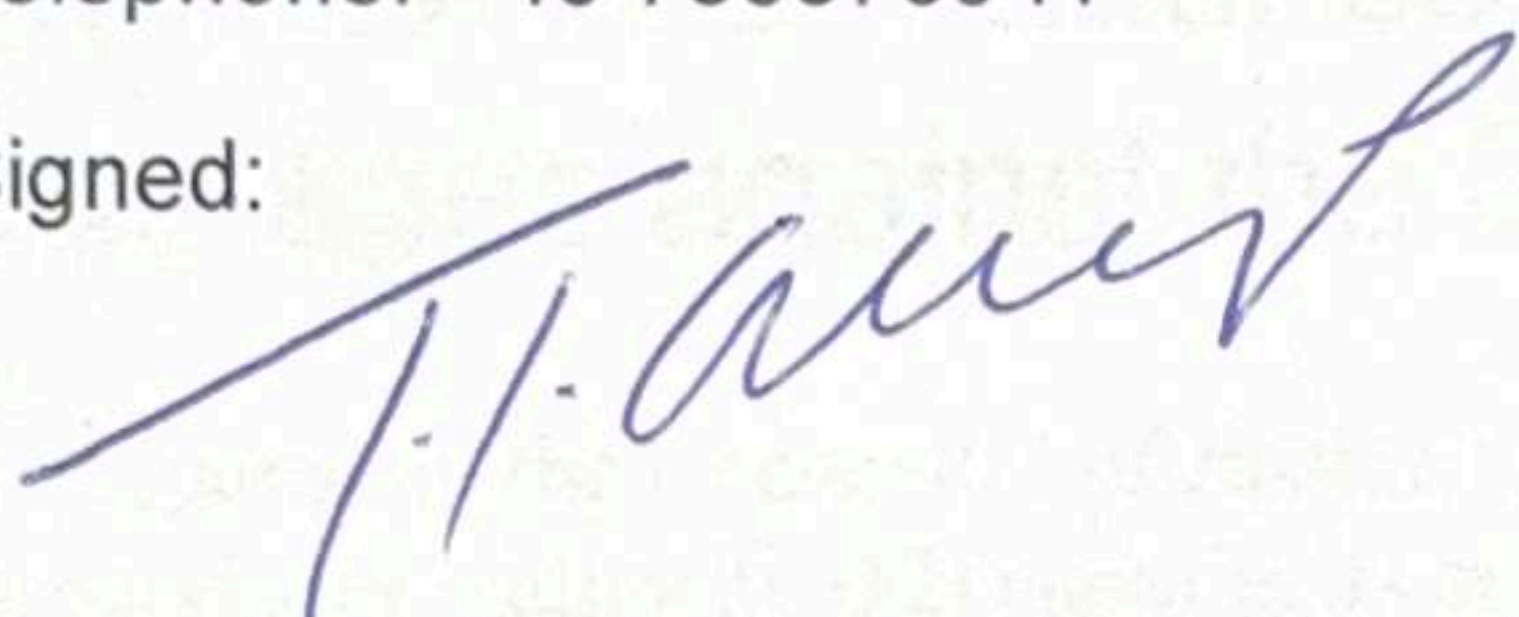
The translation is accurate, true and complete in all material respects.

Contact details

Should the recipient of this translation have any questions concerning content or veracity, please feel free to contact me:

Telephone: +46 735876941

Signed:



27 May 2026

TIMOTHY IAN CRAMP

Member of the bar of England Wales and Authorised Translator

05/05/2026



Finansinspektionen
PO Box 7821
103 97 Stockholm
Tel. +46 8 408 980 00
finansinspektionen@fi.se
www.fi.se

Chancellor of Justice
PO Box 2308
103 17 Stockholm

FI ref. no. 26-7652

By email only: registrator@justitekanslern.se

Opinion in a matter concerning a claim for damages against the State, ref. 2026/1950

In response to the Chancellor of Justice's referral, the Swedish Financial Supervisory Authority (FI) submits its opinion in the above matter.

Summary

FI considers that the authority has neither failed in its supervision under the DORA framework nor breached any rule of law. In FI's assessment, no circumstances have emerged that would give rise to the State's liability for damages, whether under the Francovich principle or under the Tort Liability Act (1972:207). As regards the financial loss that Gillsoft AB claims to have suffered and for which it seeks compensation, FI considers that the cost stems from a purely commercial decision by the company and is unconnected with FI's activities or decisions.

Circumstances to which the claim relates

FI would like to begin by noting that the authority's supervision in the ICT area concerns the financial entities covered by the DORA framework and their compliance with the DORA Regulation¹. Gillsoft AB is not a financial entity within the meaning of the DORA Regulation but is instead a third-party provider of ICT services (see the section in particular on the DORA Regulation below). FI does not supervise third-party providers. Gillsoft AB is therefore not a financial entity whose operations are directly covered by the supervisory work arising from FI's supervisory strategy and annual supervisory priorities. FI has not taken any decision in which Gillsoft AB appears as a party to the matter.

In its claim for damages, Gillsoft AB refers to two notifications that the company is said to have submitted to FI. The first notification to which the company refers, ref. 25-2410,

¹ Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector, and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011.

was, however, submitted by an anonymous sender. In the email, the complainant notes, among other things, that they consider it an absolute requirement for Getswish AB or the member banks to verify that all customers using the Swish Payout service have an HSM (hardware security module). The complainant further points out that, under existing agreements, the member banks already require the party ordering the Swish Payout service to use an HSM. As part of the authority's duty to provide assistance, FI has sent a written reply to the complainant, briefly outlining its supervisory work and thanking them for the information.

Gillsoft AB has also submitted an enquiry to FI about FI's supervisory approach to verifying cryptographic key management under the DORA Regulation (EU) 2022/2554, ref. 26-6336. As part of the authority's duty to provide assistance, FI has sent a written reply to the company, explaining that it conducts its supervision using several different methods.

Legal framework

In particular: the DORA Regulation

The DORA framework – that is, the DORA Regulation together with its implementing and delegated regulations – is intended to ensure digital operational resilience across the financial sector and applies to virtually all financial firms. The framework is relatively new and started to apply in January 2025. Implementing and delegated regulations have since been introduced on an ongoing basis throughout 2025.

Which organisations qualify as financial entities under the DORA Regulation is set out in Article 2, which lists the different types of entity, together with Article 3, which identifies those types by reference to other European financial services legislation. Among other provisions, Article 46 of the DORA Regulation provides FI with the legal basis for its supervision of the listed financial entities.

The DORA framework sets out obligations relating, among other things, to information and communication technology (ICT) risk management, the reporting of serious ICT-related incidents, testing of digital operational resilience, and the management of third-party ICT risks. In addition, the DORA framework also imposes requirements on financial firms' contractual arrangements with their third-party providers of ICT services. The DORA Regulation also governs, among other matters, various forms of information-sharing between both public and private actors, and the supervision of critical third-party ICT service providers (see Article 31 of the DORA Regulation), which is led by the European Supervisory Authorities (the European Banking Authority, the European Insurance and Occupational Pensions Authority, and the European Securities and Markets Authority).



Article 3 of the DORA Regulation sets out definitions, including the terms third-party ICT service provider and ICT services.²

Under Article 6 of the DORA Regulation, financial entities are required to have an ICT risk management framework. The requirements for this ICT risk management framework are wide-ranging and, under Article 6(2), shall “(...) *include at least strategies, policies, procedures, ICT protocols and tools that are necessary to duly and adequately protect all information assets and ICT assets (...)*”. Subsequent articles of the DORA Regulation in several cases provide additional detail on the requirements for financial entities’ ICT risk management framework.

Article 9 of the DORA Regulation sets requirements for financial entities’ work to protect ICT systems and maintain high standards of information security. To meet these objectives, financial entities must, under Article 9(3), use ICT solutions and ICT processes that are appropriate in accordance with Article 4 of the DORA Regulation, and those solutions and processes shall (i) ensure the security of the means of transfer of data, (ii) minimise the risk of corruption or loss of data, unauthorised access and technical flaws that may hinder business activity, (iii) prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data, and (iv) ensure that data is protected from risks arising from data management, including poor administration, processing-related risks and human error.

Article 9(4) of the DORA Regulation further breaks down what the financial entities’ ICT risk management framework, as referred to in Article 6 of the DORA Regulation, must include in relation to the protection of ICT systems. This section states, among other things, that the ICT risk management framework shall “(...) d) *implement policies and protocols for strong authentication mechanisms, based on relevant standards and dedicated control systems, and protection measures of cryptographic keys whereby data is encrypted based on results of approved data classification and ICT risk assessment processes (...)*”.

Article 28 of the DORA Regulation requires financial entities to manage their ICT third-party risks as an integral part of their ICT risk management framework. Among other things, item 5 states that contractual arrangements may only be entered into with third-party ICT service providers that comply with appropriate information security standards. The article also sets out requirements for the financial entity, including due diligence prior to signing a contract, and ensuring the ability to terminate contractual arrangements in the specific circumstances set out in the article.

² Article 3(19) of the DORA Regulation states that a third-party ICT service provider is “*an undertaking that provides ICT services*”. Article 3(21) of the DORA Regulation states that ICT services are “*digital and data services provided through ICT systems to one or more internal or external users on an ongoing basis, including hardware as a service and hardware services which includes the provision of technical support via software or firmware updates by the hardware provider, excluding traditional analogue telephone services*”.

Article 30 of the DORA Regulation sets out the minimum content that contractual arrangements (that is, the agreements) for the use of ICT services must include. Article 30(2)(c) states that these contractual arrangements shall, among other things, include “provisions on availability, authenticity, integrity and confidentiality in relation to the protection of data, including personal data.”

Article 9 of the DORA Regulation is supplemented by the European Commission’s delegated regulation (EU) 2024/1774, which supplements Regulation (EU) 2022/2554 of the European Parliament and of the Council as regards regulatory technical standards on supervision, specifying tools, methods, processes and strategies for ICT risk management and the simplified ICT risk management framework (RTS 2024/1774). Under Article 2(1)(c) of RTS 2024/1774, financial entities must establish ICT-related security strategies, procedures, protocols and tools that, among other things, “preserve the availability, authenticity, integrity, and confidentiality of data, including via the use of cryptographic techniques.”

Article 6 of RTS 2024/1774 sets out more detailed rules specifically on encryption and cryptographic security, namely a requirement for the financial entity to have a documented policy in this area. In brief, the Article provides that the policy must include rules on encrypting data at rest and in transit and, where necessary, in use. The policy must include the criteria the financial entity applies when selecting an encryption method, as well as provisions for updating and making changes (where necessary) to the chosen encryption technology.

Article 7 of RTS 2024/1774 states that financial entities must have a comprehensive policy for managing cryptographic keys throughout their entire lifecycle, from generation to destruction. It further follows from the Article that financial entities must implement controls to protect cryptographic keys and develop and implement methods to replace keys that are lost, compromised or damaged. A register must be created and maintained of all certificates and certificate storage devices for at least the ICT assets that support the entity’s critical or important functions. The entity is also required to ensure that certificates are renewed promptly before they expire.

FI’s supervisory strategy and priorities in ICT risk supervision

FI is responsible for supervision, rulemaking, licensing and registration relating to financial markets and financial firms. This includes working towards a stable financial system, characterised by high confidence and healthy competition, and capable of safeguarding essential societal functions. Financial markets must function well. The authority also works to ensure that financial firms meet households’ and businesses’ needs for financial services, take responsibility for robust consumer protection, and contribute to sustainable development.



The way FI conducts its supervisory work is set out in FI's supervisory strategy.³ Supervision is conducted to ensure that participants in the financial market act in line with the applicable regulations and, in doing so, contribute to a stable and well-functioning financial market. Failures to comply may have significant consequences both for the wider economy and for individual firms and consumers. FI's work on ICT risk supervision is based on this overarching supervisory strategy.

Through the DORA Regulation, FI has been given an expanded and more wide-ranging remit for supervising ICT risks. The scope of the entities covered is also very broad. In practice, the DORA Regulation and the extensive implementing regulations apply to virtually all financial entities authorised by FI and subject to FI's supervision, i.e. just over 2 000 firms.

As in its other supervisory work, FI applies a risk-based approach to supervision in the ICT area. This risk-based approach is grounded in global standards for financial-market supervision.⁴ This means resources are focused on areas where risks are highest and where the potential consequences of non-compliance could be significant. Supervision is always based on a thorough analysis, and activities are tailored to achieve the best possible outcomes.

All entities under FI's supervision are subject to ongoing supervision. Through planned analyses and reviews, both quantitative and qualitative, FI ensures that financial firms and market transactions meet the rules and requirements that apply to them. Ongoing supervision is also, to some extent, event-driven and, together with the results of the authority's planned analyses and reviews, provides the basis for the authority's risk-based priorities. A key element is written and oral supervisory dialogue, which enables FI to track developments in, for example, ICT risks within firms and across the market as a whole.

In addition to ongoing supervision, FI may initiate in-depth analyses and investigations. In-depth analyses within ICT risk supervision are intended to deepen FI's understanding of specific ICT-related issues and risks. Surveys, referred to in the damages claim, are an example of an in-depth analysis through which FI maps, on a broad basis, how firms relate to the obligations and requirements in the DORA Regulation. As the DORA Regulation only began to be applied by firms on 17 January 2025, the survey results are an important tool for the prioritisation carried out within risk-based supervision.

In FI's supervisory priorities for 2026, ICT risks are identified as one of the authority's supervisory priorities: "During 2026, we will continue our work on supervising information and communication technology risks (ICT risks) and protective security. We will, in particular, analyse reported data linked to

³ Supervisory strategy (1 November 2022), FI ref. no. 22-24464.

⁴ See, for example, FATF (Financial Action Task Force) guidance on risk-based supervision and the Basel Framework, Core Principles for Effective Banking Supervision.



the Digital Operational Resilience Act (Dora) regulatory framework to identify risks and to ensure robust compliance with the rules.”⁵

FI's assessment

Question of entitlement to damages under the Francovich principle

Gillsoft AB considers that FI has failed in its supervisory duties and that, as a result, the company is entitled to compensation for the costs it incurred in investing in certain hardware, licences and publication expenses. In support of its position, Gillsoft AB has referred to a number of provisions in the Dora framework which, in the company's view, in practice amount to requirements that presuppose financial entities use automated cryptographic verification of key management.

The FI considers that the authority has neither fallen short in its supervision nor breached any legal rule. Gillsoft AB is a third-party provider under the Dora Regulation (see Article 3(19) of the Dora Regulation) and not a financial entity (cf. Article 2(2) of the Dora Regulation). FI first notes that the Dora framework's provisions on ICT risk management, including requirements relating to information security and protection through encryption, impose obligations on financial undertakings (entities) and do not confer rights on third-party providers of ICT services such as Gillsoft AB. As a third-party provider of ICT services, Gillsoft AB is not subject to FI's supervision (cf. Article 46 of the Dora Regulation), and the authority has not made any decision to which the company is a party. It is worth noting that, even if FI in its supervisory work specifically checks whether financial entities verify cryptographic key management, this does not mean that Gillsoft AB would thereby acquire any right. The first condition under the Francovich principle – namely that the breached rule of law must be intended to confer rights on individuals – is therefore not met.

As regards its supervisory activities, FI further notes that the Dora framework, as set out above, is a wide-ranging set of rules that is to be applied in relation to, in principle, all entities supervised by FI. FI applies a risk-based supervisory approach, meaning that ICT risk supervision is driven by the risks the authority assesses to be the most significant. FI's use of a risk-based supervisory method in line with global standards does not mean that EU law, or an individual's rights, has been infringed.

Against this background, FI considers that the second requirement under the Francovich principle is also not met, i.e. that there must have been a sufficiently clear breach of EU law.

Since, in FI's assessment, there has been no breach on the authority's part, the authority considers that there is likewise no causal link to the loss Gillsoft AB claims to have suffered. FI therefore considers that the final requirement under the Francovich principle is also not met,

⁵ FI's supervisory priorities for 2026 (2026-02-05), FI ref. no. 26-1304.



i.e. there must be a direct causal link between the breach and the loss suffered by the individual. FI therefore considers that the company's claim for damages on this basis should be rejected.

Issue of entitlement to damages under the Tort Liability Act

As previously stated, FI has not made any decision in which Gillsoft AB is a party, and the company is not subject to the authority's supervision. FI has only, as part of its duty to provide service, replied to an email from the company (ref. 26-6336). The company has therefore not been subject to any exercise of public authority by FI. Nor has the company shown that any error or negligence occurred on the authority's part in its contacts with FI, or that the inspection provided the company with any incorrect advice or information. No circumstances have been presented that could indicate any breach of the European Convention on Human Rights in relation to the company.

As regards the alleged loss of SEK 352 000 that Gillsoft AB claims to have suffered, the company states that this corresponds to costs for purchasing certain hardware, licences and publication costs, with the aim of offering a service which the company considers to be beneficial to financial entities in their compliance with the DORA regulatory framework. FI considers that such an investment is based on a purely commercial decision by the company and has no connection with FI's activities or decisions. Nor is it the result of any negligent conduct or other action by FI that could give rise to liability for damages.

Overall, FI considers that the conditions for compensation under the Tort Liability Act are not met and that the company's claim should therefore also be rejected on this ground.

THE SWEDISH FINANCIAL SUPERVISORY AUTHORITY

Erik Blommé
Chief Legal Counsel

Ashtar Yakob
Senior Counsel

This document has been electronically signed.



APOSTILLE

(Convention de La Haye du 5 octobre 1961)

1. Country: Sweden

This public document

2. has been signed by Timothy Ian Cramp

3. acting in the capacity of Authorized translator

4. bears the seal/stamp of The Legal, Financial and Administrative
Services Agency

Certified

5. at Stockholm

6. The 2026-05-28

7. by Rickard Grönstedt, Notary Public

8. N° 1468-26

9. Seal/stamp

10. Signature



.....
